

Active Infrastructure Identification

A web application's infrastructure is what keeps it running and allows it to function. Web servers are directly involved in any web application's operation. Some of the most popular are Apache, Nginx, and Microsoft IIS, among others.

If we discover the webserver behind the target application, it can give us a good idea of what operating system is running on the back-end server. For example, if we find out the IIS version running, we can infer the Windows OS version in use by mapping the IIS version back to the Windows version that it comes installed on by default. Some default installations are:

- IIS 6.0: Windows Server 2003
- IIS 7.0-8.5: Windows Server 2008 / Windows Server 2008R2
- IIS 10.0 (v1607-v1709): Windows Server 2016
- IIS 10.0 (v1809-): Windows Server 2019

Although this is usually correct when dealing with Windows, we can not be sure in the case of Linux or BSD-based distributions as they can run different web server versions in the case of Nginx or Apache. This kind of technology could interfere with or alter our future testing activities. Nevertheless, if we deal with a web server, we will not be able to find any fingerprints about the server in HTML or JS.

Web Servers

We need to discover as much information as possible from the webserver to understand its functionality, which can affect future testing. For example, URL rewriting functionality, load balancing, script engines used on the server, or an **Intrusion detection system (IDS)** in place may impede some of our testing activities.

The first thing we can do to identify the webserver version is to look at the response headers.

HTTP Headers

HTTP Headers
<pre>dbcypth0n@htb[/htb]\$ curl -I "http://\${TARGET}" HTTP/1.1 200 OK Date: Thu, 23 Sep 2021 15:10:42 GMT Server: Apache/2.4.25 (Debian) X-Powered-By: PHP/7.3.5 Link: <http://192.168.10.10/wp-json/>; rel="https://api.w.org/" Content-Type: text/html; charset=UTF-8</pre>

There are also other characteristics to take into account while fingerprinting web servers in the response headers. These are:

- X-Powered-By header: This header can tell us what the web app is using. We can see values like PHP, ASP.NET, JSP, etc.
- Cookies: Cookies are another attractive value to look at as each technology by default has its cookies. Some of the default cookie values are:
 - .NET: **ASPSESSIONID<RANDOM>=<COOKIE_VALUE>**
 - PHP: **PHPSESSID=<COOKIE_VALUE>**
 - JAVA: **JSESSION=<COOKIE_VALUE>**

HTTP Headers

```
dbcypth0n@htb[/htb]$ curl -I http://${TARGET}

HTTP/1.1 200 OK
Host: randomtarget.com
Date: Thu, 23 Sep 2021 15:12:21 GMT
Connection: close
X-Powered-By: PHP/7.4.21
Set-Cookie: PHPSESSID=gt02b1pqla35cvmbb2bcli96ml; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-type: text/html; charset=UTF-8
```

Other available tools analyze common web server characteristics by probing them and comparing their responses with a database of signatures to guess information like web server version, installed modules, and enabled services. Some of these tools are:

[Whatweb](#) recognizes web technologies, including content management systems (CMS), blogging platforms, statistic/analytics packages, JavaScript libraries, web servers, and embedded devices. We recommend reading the [whatweb](#) help menu via `whatweb -h` to understand the available options, like the aggression level controls or verbose output. In this case, we will use an aggression level of 3 via the `-a` flag and verbose output via `-v`.

WhatWeb

WhatWeb

```
dbcypth0n@htb[/htb]$ whatweb -a3 https://www.facebook.com -v

WhatWeb report for https://www.facebook.com
Status      : 200 OK
Title       : <None>
IP          : 31.13.92.36
Country     : IRELAND, IE

Summary      : Strict-Transport-Security[max-age=15552000; preload], PasswordField[pass], Script[text/javascript]

Detected Plugins:
[ HTML5 ]
    HTML version 5, detected by the doctype declaration

[ Meta-Refresh-Redirect ]
    Meta refresh tag is a deprecated URL element that can be
    used to optionally wait x seconds before reloading the
    current page or loading a new page. More info:
    https://secure.wikimedia.org/wikipedia/en/wiki/Meta_refresh

    String      : /?_fb_noscript=1

[ PasswordField ]
    find password fields

    String      : pass (from field name)

[ Script ]
    This plugin detects instances of script HTML elements and
    returns the script language/type.

    String      : text/javascript

[ Strict-Transport-Security ]
    Strict-Transport-Security is an HTTP header that restricts
    a web browser from accessing a website without the security
    of the HTTPS protocol.
```

```
String      : max-age=15552000; preload

[ UncommonHeaders ]
  Uncommon HTTP server headers. The blacklist includes all
  the standard headers and many non standard but common ones.
  Interesting but fairly common headers should have their own
  plugins, eg. x-powered-by, server and x-aspnet-version.
  Info about headers can be found at www.http-stats.com

String      : x-fb-rlafr,x-content-type-options,x-fb-debug,alt-svc (from headers)

[ X-Frame-Options ]
  This plugin retrieves the X-Frame-Options value from the
  HTTP header. - More Info:
  http://msdn.microsoft.com/en-us/library/cc288472%28VS.85%29.
  aspx

String      : DENY

[ X-XSS-Protection ]
  This plugin retrieves the X-XSS-Protection value from the
  HTTP header. - More Info:
  http://msdn.microsoft.com/en-us/library/cc288472%28VS.85%29.
  aspx

String      : 0

HTTP Headers:
  HTTP/1.1 200 OK
  Vary: Accept-Encoding
  Content-Encoding: gzip
  x-fb-rlafr: 0
  Pragma: no-cache
  Cache-Control: private, no-cache, no-store, must-revalidate
  Expires: Sat, 01 Jan 2000 00:00:00 GMT
  X-Content-Type-Options: nosniff
  X-XSS-Protection: 0
  X-Frame-Options: DENY
  Strict-Transport-Security: max-age=15552000; preload
  Content-Type: text/html; charset="utf-8"
  X-FB-Debug: r2w+sMJ7lVrMjS/ETitC6cNpJXma0r3fbt0rIlnTPAfQqTc+U4PQopVL7sR/6YA/ZKRkqP1wMPoFdUfMBP1JSA==
  Date: Wed, 06 Oct 2021 09:04:27 GMT
  Alt-Svc: h3=":443"; ma=3600, h3-29=":443"; ma=3600, h3-27=":443"; ma=3600
  Connection: close

WhatWeb report for https://www.facebook.com/?_fb_noscript=1
Status      : 200 OK
Title       : <None>
IP          : 31.13.92.36
Country     : IRELAND, IE

Summary     : Cookies[noscript], Strict-Transport-Security[max-age=15552000; preload], PasswordField[pass], Scrip

Detected Plugins:
[ Cookies ]
  Display the names of cookies in the HTTP headers. The
  values are not returned to save on space.

String      : noscript

[ HTML5 ]
  HTML version 5, detected by the doctype declaration

[ PasswordField ]
  find password fields

String      : pass (from field name)

[ Script ]
  This plugin detects instances of script HTML elements and
  returns the script language/type.
```

```

String      : text/javascript

[ Strict-Transport-Security ]
  Strict-Transport-Security is an HTTP header that restricts
  a web browser from accessing a website without the security
  of the HTTPS protocol.

String      : max-age=15552000; preload

[ UncommonHeaders ]
  Uncommon HTTP server headers. The blacklist includes all
  the standard headers and many non standard but common ones.
  Interesting but fairly common headers should have their own
  plugins, eg. x-powered-by, server and x-aspnet-version.
  Info about headers can be found at www.http-stats.com

String      : x-fb-rlafr,x-content-type-options,x-fb-debug,alt-svc (from headers)

[ X-Frame-Options ]
  This plugin retrieves the X-Frame-Options value from the
  HTTP header. - More Info:
  http://msdn.microsoft.com/en-us/library/cc288472%28VS.85%29.
  aspx

String      : DENY

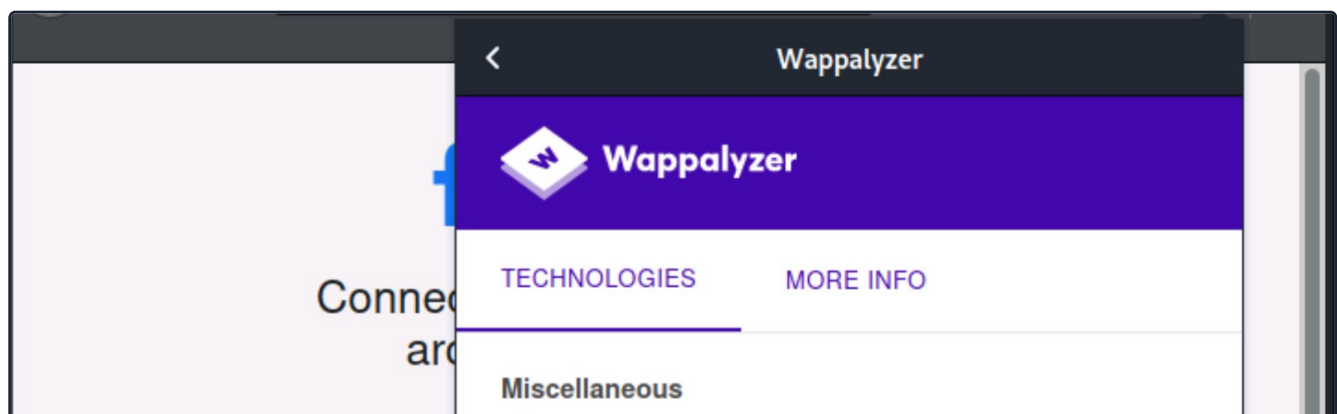
[ X-XSS-Protection ]
  This plugin retrieves the X-XSS-Protection value from the
  HTTP header. - More Info:
  http://msdn.microsoft.com/en-us/library/cc288472%28VS.85%29.
  aspx

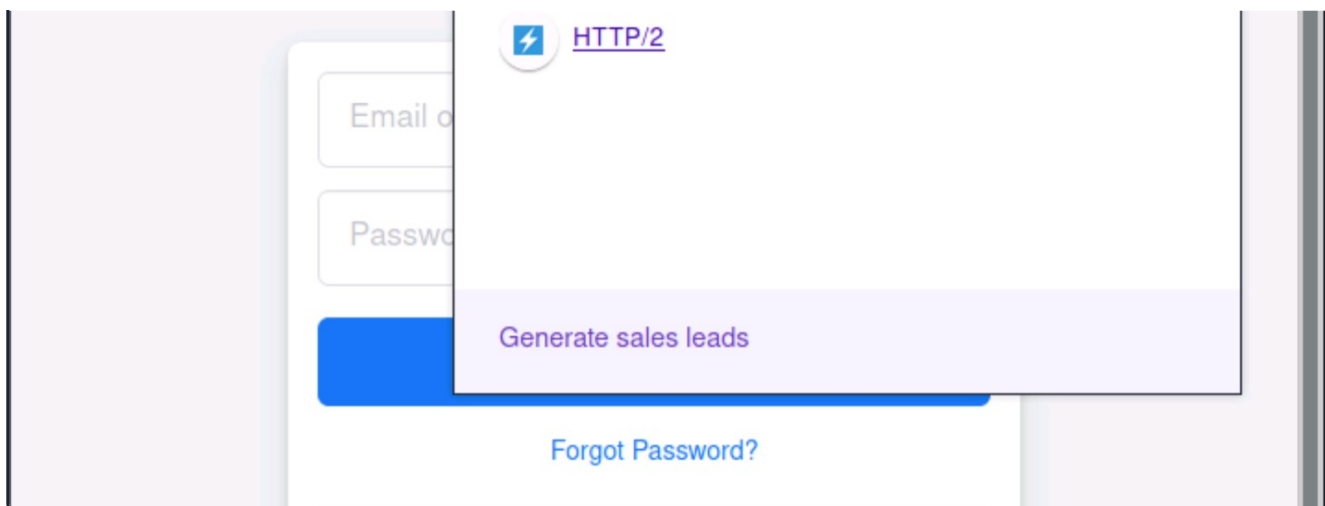
String      : 0

HTTP Headers:
HTTP/1.1 200 OK
Vary: Accept-Encoding
Content-Encoding: gzip
Set-Cookie: noscript=1; path=/; domain=.facebook.com; secure
x-fb-rlafr: 0
Pragma: no-cache
Cache-Control: private, no-cache, no-store, must-revalidate
Expires: Sat, 01 Jan 2000 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 0
X-Frame-Options: DENY
Strict-Transport-Security: max-age=15552000; preload
Content-Type: text/html; charset="utf-8"
X-FB-Debug: 7bEryjJ3tsTb/ap562d5L6KUJyJJ3bJh9XoamIo2lCVrX4cK/VAGbLx7muaAwnyobVm9myC3fQ+CXJqkk0eacg==
Date: Wed, 06 Oct 2021 09:04:31 GMT
Alt-Svc: h3=":443"; ma=3600, h3-29=":443"; ma=3600, h3-27=":443"; ma=3600
Connection: close

```

We also would want to install [Wappalyzer](#) as a browser extension. It has similar functionality to Whatweb, but the results are displayed while navigating the target URL.





WafW00f is a web application firewall (WAF) fingerprinting tool that sends requests and analyses responses to determine if a security solution is in place. We can install it with the following command:

Installing WafW00f

Installing WafW00f

```
dbcypthn@htb[/htb]$ sudo apt install wafw00f -y
```

We can use options like **-a** to check all possible WAFs in place instead of stopping scanning at the first match, read targets from an input file via the **-i** flag, or proxy the requests using the **-p** option.

Installing WafW00f

```
dbcypthn@htb[/htb]$ wafw00f -v https://www.tesla.com
```

```

      /-----\
     (  Woof!  )
      \-----/
         ""
      .--'-----'
     (  ) ; |==|-----
      /  ( '      /|\
     ( / )      / | \
    \(_)_ )    /  |  \

```

```

    )
   ) (
  ( |__|
  .) |__|
  ( |__|
  . |__|
  |__|

```

~ WAFW00F : v2.1.0 ~

The Web Application Firewall Fingerprinting Toolkit

```
[*] Checking https://www.tesla.com
```

```
[+] The site https://www.tesla.com is behind CacheWall (Varnish) WAF.
```

```
[~] Number of requests: 2
```

Aquatone is a tool for automatic and visual inspection of websites across many hosts and is convenient for quickly gaining an overview of HTTP-based attack surfaces by scanning a list of configurable ports, visiting the website with a headless Chrome browser, and taking a screenshot. This is helpful, especially when dealing with huge subdomain lists. **Aquatone** is not installed by default in Parrot Linux, so we will need to install via the following commands.

Installing Aquatone

Installing Aquatone

```
dbcypthn@htb[/htb]$ sudo apt install golang chromium-driver
```

```
dbcypthon@htb[/htb]$ sudo apt install golang chromium-driver
dbcypthon@htb[/htb]$ go get github.com/michenriksen/aquatone
dbcypthon@htb[/htb]$ export PATH="$PATH":"$HOME/go/bin"
```

After this, we need to explore some options:

Aquatone Options

Aquatone Options

```
dbcypthon@htb[/htb]$ aquatone --help

Usage of aquatone:
  -chrome-path string
    Full path to the Chrome/Chromium executable to use. By default, aquatone will search for Chrome or Chromium
  -debug
    Print debugging information
  -http-timeout int
    Timeout in milliseconds for HTTP requests (default 3000)
  -nmap
    Parse input as Nmap/Masscan XML
  -out string
    Directory to write files to (default ".")
  -ports string
    Ports to scan on hosts. Supported list aliases: small, medium, large, xlarge (default "80,443,8000,8080")
  -proxy string
    Proxy to use for HTTP requests
  -resolution string
    screenshot resolution (default "1440,900")
  -save-body
    Save response bodies to files (default true)
  -scan-timeout int
    Timeout in milliseconds for port scans (default 100)
  -screenshot-timeout int
    Timeout in milliseconds for screenshots (default 30000)
  -session string
    Load Aquatone session file and generate HTML report
  -silent
    Suppress all output except for errors
  -template-path string
    Path to HTML template to use for report
  -threads int
    Number of concurrent threads (default number of logical CPUs)
  -version
    Print current Aquatone version
```

Now, it's time to use `cat` in our subdomain list and pipe the command to `aquatone` via:

Aquatone Options

```
dbcypthon@htb[/htb]$ cat facebook_aquatone.txt | aquatone -out ./aquatone -screenshot-timeout 1000

aquatone v1.7.0 started at 2021-10-06T10:14:42+01:00

Targets      : 30
Threads      : 2
Ports        : 80, 443, 8000, 8080, 8443
Output dir   : aquatone

edge-star-shv-01-cdg2.facebook.com: port 80 open
edge-extern-shv-01-waw1.facebook.com: port 80 open
whatsapp-chatd-edge-shv-01-ams4.facebook.com: port 80 open
edge-secure-shv-01-ham3.facebook.com: port 80 open
sv-se.facebook.com: port 80 open
ko.facebook.com: port 80 open
whatsapp-chatd-msgr-mini-edge-shv-01-lis1.facebook.com: port 80 open
synthetic-e2e-elbprod-sli-shv-01-otp1.facebook.com: port 80 open
edge-star-shv-01-cdd2.facebook.com: port 443 open
```

```

edge-extern-shv-01-waw1.facebook.com: port 443 open
whatsapp-chatd-edge-shv-01-ams4.facebook.com: port 443 open
http://edge-star-shv-01-cdg2.facebook.com/: 200 OK
http://edge-extern-shv-01-waw1.facebook.com/: 200 OK
edge-secure-shv-01-ham3.facebook.com: port 443 open
ondemand-edge-shv-01-cph2.facebook.com: port 443 open
sv-se.facebook.com: port 443 open
http://edge-secure-shv-01-ham3.facebook.com/: 200 OK
ko.facebook.com: port 443 open
whatsapp-chatd-msgr-mini-edge-shv-01-lis1.facebook.com: port 443 open
http://sv-se.facebook.com/: 200 OK
http://ko.facebook.com/: 200 OK
synthetic-e2e-elbprod-sli-shv-01-otp1.facebook.com: port 443 open
http://synthetic-e2e-elbprod-sli-shv-01-otp1.facebook.com/: 400 default_vip_400
https://edge-star-shv-01-cdg2.facebook.com/: 200 OK
https://edge-extern-shv-01-waw1.facebook.com/: 200 OK
http://edge-star-shv-01-cdg2.facebook.com/: screenshot timed out
http://edge-extern-shv-01-waw1.facebook.com/: screenshot timed out
https://edge-secure-shv-01-ham3.facebook.com/: 200 OK
https://sv-se.facebook.com/: 200 OK
https://ko.facebook.com/: 200 OK
http://edge-secure-shv-01-ham3.facebook.com/: screenshot timed out
http://sv-se.facebook.com/: screenshot timed out
http://ko.facebook.com/: screenshot timed out
https://synthetic-e2e-elbprod-sli-shv-01-otp1.facebook.com/: 400 default_vip_400
http://synthetic-e2e-elbprod-sli-shv-01-otp1.facebook.com/: screenshot successful
https://edge-star-shv-01-cdg2.facebook.com/: screenshot timed out
https://edge-extern-shv-01-waw1.facebook.com/: screenshot timed out
https://edge-secure-shv-01-ham3.facebook.com/: screenshot timed out
https://sv-se.facebook.com/: screenshot timed out
https://ko.facebook.com/: screenshot timed out
https://synthetic-e2e-elbprod-sli-shv-01-otp1.facebook.com/: screenshot successful
Calculating page structures... done
Clustering similar pages... done
Generating HTML report... done

```

Writing session file...Time:

- Started at : 2021-10-06T10:14:42+01:00
- Finished at : 2021-10-06T10:15:01+01:00
- Duration : 19s

Requests:

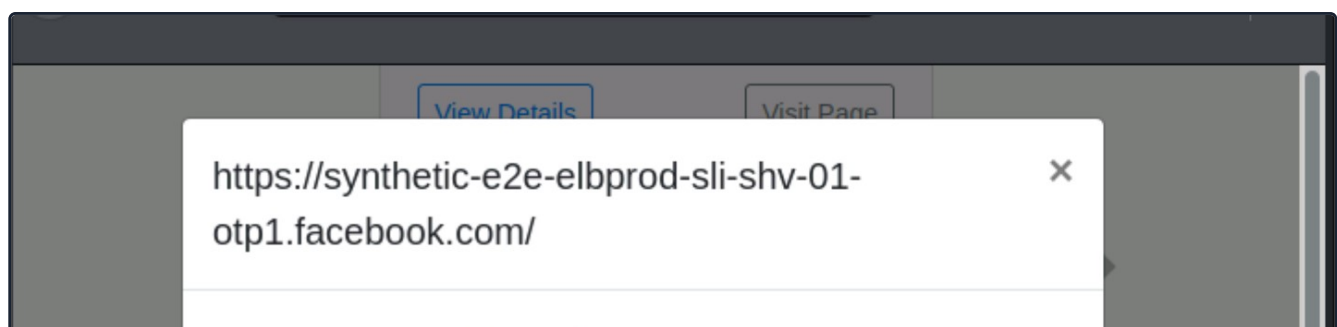
- Successful : 12
- Failed : 5
- 2xx : 10
- 3xx : 0
- 4xx : 2
- 5xx : 0

Screenshots:

- Successful : 2
- Failed : 10

Wrote HTML report to: aquatone/aquatone_report.html

When it finishes, we will have a file called [aquatone_report.html](#) where we can see screenshots, technologies identified, server response headers, and HTML.



Response Headers:

Header	Value
Proxy-Status	http_request_error; e_fb_vipaddr="AcJlYwDeEgc0PXuZep8s8Cruvw6FaymfNmogHsIX5HZ48R5aFzyWDl_sSNKRQioeM92idLrgNE"; e_clientaddr="AcLy2AkiJTHLvj_hyFoe7Z1_0km6jQ08qkYRyL0ZBgCNAMN93fER0GyPKzf_zKP0UyRlSJTrG_PcnsKX"; e_fb_builduser="AcLX1bDCv6et1yUa5j7UT6cI_ZyyWw8p_lDjt5tdJA-hvV817E3PHDMzgCf00V0Nxxhg"; e_proxy="AcKdg0u0KrkDCDDqTP-8SK63yUS0QNTKMUs0559kUr4JvVsEb3l9lHSpnsWso2Ubd0IdI3gSq74Hpm0"; e_fb_binaryversion="AcIt-HBGTXQ9GHCRp31-WLKSYAgXUS9eacMAcpbKGZ7Yw6rzNgXbvtKc_xth1mLAnk-iuhu91E1slhbbmVD0c3qs1BPxb4fyJwU"
Content-Type	text/plain
Server	proxygen-bolt
Date	Wed, 06 Oct 2021 09:14:49 GMT

VPN Servers

 **Warning:** Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

Existing PwnBox instances will automatically switch to the new VPN server.

us-academy-1

PROTOCOL

 UDP 1337  TCP 443

DOWNLOAD VPN CONNECTION FILE

Start Instance

∞ / 1 spawns left

Waiting to start...

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target: [Click here to spawn the target system!](#)

vHosts needed for these questions:

- [app.inlanefreight.local](#)
- [dev.inlanefreight.local](#)

+ 1  What Apache version is running on app.inlanefreight.local? (Format: 0.0.0)

Submit your answer here...

 Submit

+ 1  Which CMS is used on app.inlanefreight.local? (Format: word)

Submit your answer here...

 Submit

+ 1  On which operating system is the dev.inlanefreight.local webserver running on? (Format: word)

Submit your answer here...

 Submit

 Previous

Next 

 Cheat Sheet

 Go to Questions

Table of Contents

Information Gathering



Passive Information Gathering

 WHOIS DNS

Passive Subdomain Enumeration



Passive Infrastructure Identification



Active Information Gathering

 [Active Infrastructure Identification](#) Active Subdomain Enumeration Virtual Hosts

Crawling

Putting it all Together

 Information Gathering - Web - Skills Assessment

My Workstation

OFFLINE

 Start Instance / 1 spawns left